



infocomm
AMÉRICA LATINA

Cuando IT frena tu proyecto AV

Seguridad que se diseña, no se parcha

22 de octubre de 2026 · WTC, Ciudad de México

Parte 1: Juan Pineda · Service Delivery Manager / Tech Academy Lead · Pyxis

Parte 2: Eduardo Travi · Business Development Manager, CTS · AVI SPL

pyxis

AVI  SPL



¿Qué vamos a hacer en estos 90 minutos?

Parte 1 · 45 minutos

Juan Pineda · Pyxis

- Por qué IT frena un proyecto AV: el marco de seguridad y el ciclo de vida de un ataque.
- Mini demos en vivo sobre una red aislada que montamos en la sala.

Parte 2 · Prueba de concepto

Eduardo Travi · AVI SPL

- Un caso real con SIP: cómo fugas pequeñas se combinan y terminan en un phishing dirigido.
- De la teoría a la práctica, demostrado en vivo.

No necesitas laptop: participas desde tu teléfono, sobre nuestra propia red WiFi.

Puedes seguir sin instalar nada; el escáner de red es opcional. El kit se descarga después.



Antes de empezar: uso responsable



Escanear o probar sistemas sin autorización escrita del dueño es un delito.

Ni en el recinto, ni en tu empresa, ni en la de un cliente. Hoy, solo sobre la red aislada del laboratorio.

Colombia: Ley 1273 de 2009, art. 269A · Argentina: Ley 26.388, art. 153 bis · México: Código Penal Federal, arts. 211 bis 1 a 7

Fines educativos

Todo lo que ves hoy es para aprender a diseñar y defender instalaciones AV.

Capturas de ejemplo

Las imágenes de las demos son ilustrativas; no corresponden a ningún cliente ni sistema real.

Opiniones propias

Criterio de los presentadores; no representa a fabricantes ni a los organizadores. Las marcas se omiten a propósito.

El kit

Es para practicar en tu propio entorno de laboratorio.

Esto no es asesoría legal: consulta la legislación vigente de tu país.



Tu proyecto AV está listo. Entonces IT lo revisa y lo frena.

El problema no es tu diseño. Es que la seguridad se pensó al final, no desde el día uno.



Los pecados que IT ve en tu rack

Interfaces sin autenticación

Paneles y APIs abiertos a cualquiera en la red.

Ej.: el panel del códec sin clave.

Credenciales de fábrica

admin / admin en equipos carísimos.

Ej.: la contraseña que nunca se cambió.

Protocolos legacy y sin cifrar

mDNS, Telnet, HTTP plano: tráfico al descubierto.

Ej.: mDNS anunciando el equipo a todos.

Firmware y software viejo

Versiones con vulnerabilidades conocidas, sin parchar.

Ej.: un CVE público del modelo exacto.

Sin visibilidad

Ni logs ni monitoreo: nadie ve lo que pasa.

Ej.: un acceso raro que nadie registra.

Acceso físico al rack

Diez segundos frente al equipo alcanzan.

Ej.: un puerto libre en el switch.

Son las vulnerabilidades comunes que describe AVIXA RP-C303.01, §5.2.



Lo que IT ve cuando mira tu equipo AV

Lo que ves tú

Un códec.

Un DSP.

Un controlador.

Un equipo AV que hace su trabajo.

Lo que ve IT

- Un sistema operativo.
- Servicios de red y puertos abiertos.
- A veces, salida a internet.
- Un host que ellos no administran.

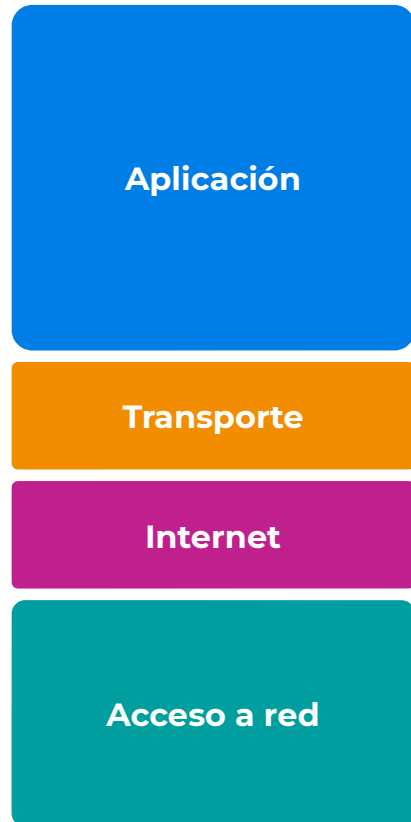
Por eso no desconfían de ti. Desconfían de un host desconocido en su red.



Las capas de red: OSI y TCP/IP

TCP / IP

OSI



mDNS, HTTP de admin, APIs, NDI, control de Dante y AES67. Aquí vive lo que exponemos.

Formatos y cifrado de datos (TLS, SRTP).

Señalización de sesión. Ej.: SIP, RTSP. SIP lo verá Eduardo.

TCP / UDP y puertos. RTP lleva el audio y el video. Lo que nmap enumera.

IP, enrutamiento y multicast (IGMP). Se segmenta con subredes.

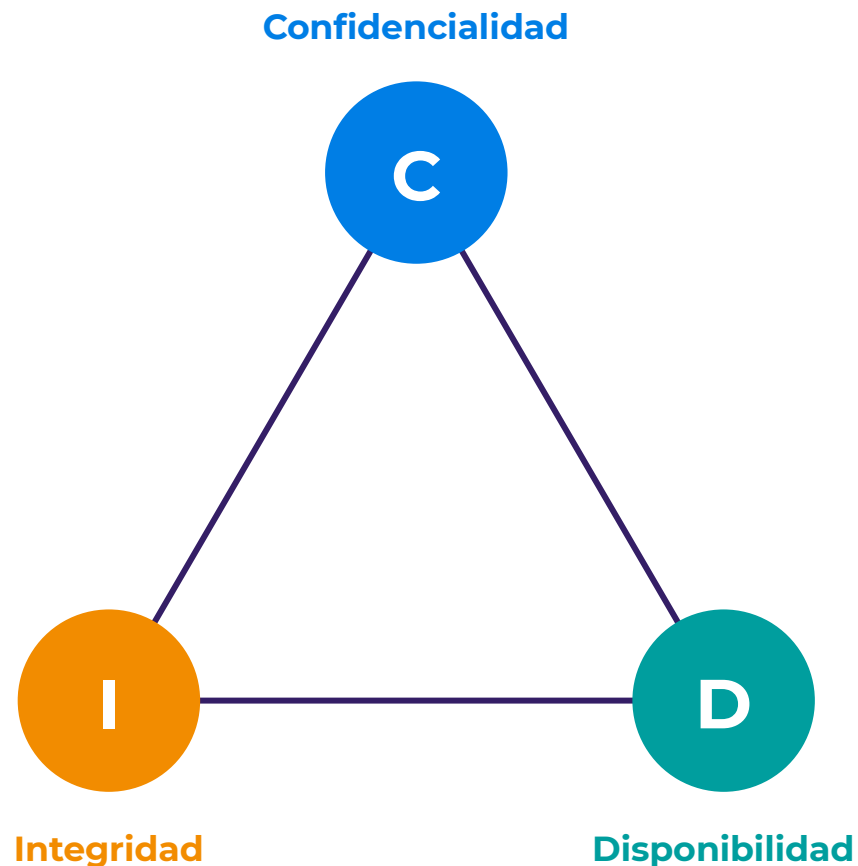
MAC, VLAN, AVB/TSN y PTP para la sincronía. Aquí IT separa el AV.

El cable (Cat6, fibra, HDBaseT) y el puerto del rack.

mDNS y paneles viven en la 7; IT segmenta en 2 y 3; el cifrado cubre 4 a 6.
nmap enumera la capa 4 y Wireshark lee de la 2 a la 7. Las dos, en las demos.



Marco 1: la tríada CIA



Confidencialidad

Que la señal y las credenciales no las vea quien no debe.
Ej.: **streaming sin cifrar.**



Integridad

Que nadie altere lo emitido ni la configuración.
Ej.: **firmware sin firmar.**



Disponibilidad

Que el sistema esté cuando se lo necesita.
Ej.: **la sala del directorio, caída en vivo.**



Marco 2: la hexada de Parker

Donn Parker amplió la tríada con tres elementos más. Dos de ellos pesan mucho en AV.



Confidencialidad

Ya vista: que no lo vea quien no debe.



Integridad

Ya vista: que nadie lo altere.



Disponibilidad

Ya vista: que esté cuando se necesita.



CLAVE EN AV

Posesión o control

Que el equipo siga bajo tu control. Ej.: quien tiene el rack, tiene el equipo.



CLAVE EN AV

Autenticidad

Que lo que llega sea de quien dice ser. Ej.: ¿este firmware es del fabricante?



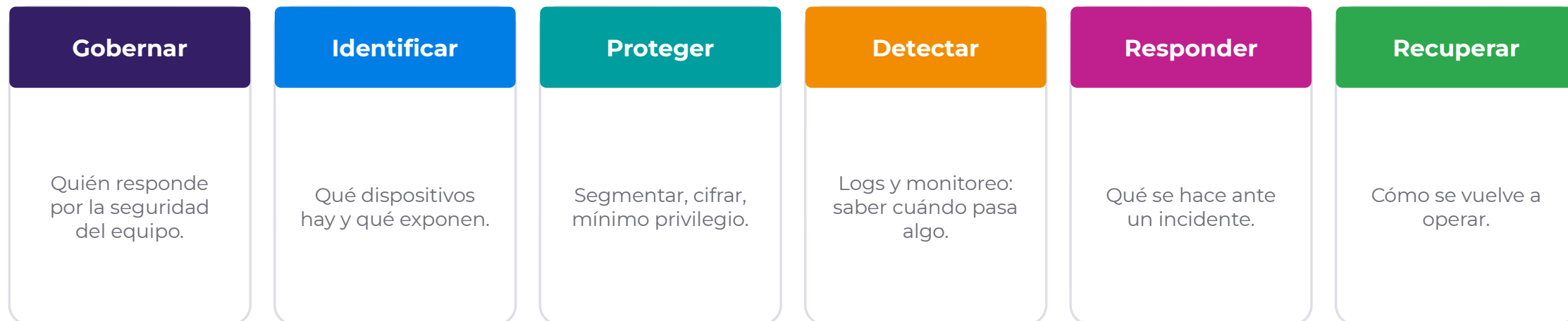
Utilidad

Que la información sirva. Ej.: una grabación cifrada cuya clave se perdió.

Cada marco mira el mismo problema con más detalle. El siguiente lo organiza como lo hace IT.



Marco 3: NIST CSF 2.0



El integrador toca sobre todo Identificar y Proteger.



Marco 4: defensa en profundidad

Defensa en profundidad

Varias capas de protección: si una falla, el ataque no llega al final.

CAPA 1 Mínimo privilegio

Cada equipo y usuario, solo lo que necesita.

CAPA 2 Segmentación

El AV en su propia red, aparte de corporativa e invitados.

CAPA 3 Cifrado

Control y señal protegidos en tránsito, no en texto plano.

CAPA 4 Credenciales gestionadas

Nada de admin/admin; cuentas administradas y rotadas.

Son las mismas capas que vamos a ver atacadas, paso a paso, en el resto de la sesión.

Por qué IT es tan restrictivo: porque conoce el ciclo de vida de un ataque.

No hace falta un atacante sofisticado. Hace falta una cadena de descuidos pequeños. Veamos esa cadena.



Mapa 1: el ciclo de vida de un ataque

Cyber Kill Chain (Lockheed Martin): las 7 etapas.



Mapa 2 — MITRE ATT&CK detalla cada etapa en tácticas y técnicas. Lo vemos enseguida.

No hace falta un atacante sofisticado.

Hace falta una cadena de descuidos pequeños. La recorremos con demos, cada una con su táctica ATT&CK.



Mapa 2: MITRE ATT&CK

MITRE ATT&CK

Base de conocimiento de comportamientos reales de atacantes.

Táctica = el QUÉ

El objetivo que el atacante quiere conseguir en un momento dado.

Técnica = el CÓMO

El método que usa para lograrlo. Las subtécnicas son sus variantes.

Las 14 tácticas de ATT&CK Enterprise. Resaltadas, las 4 que recorreremos hoy:

Reconnaissance

Resource Dev.

Initial Access

Execution

Persistence

Priv. Escalation

Defense Evasion

Credential Access

Discovery

Lateral Movement

Collection

Command & Control

Exfiltration

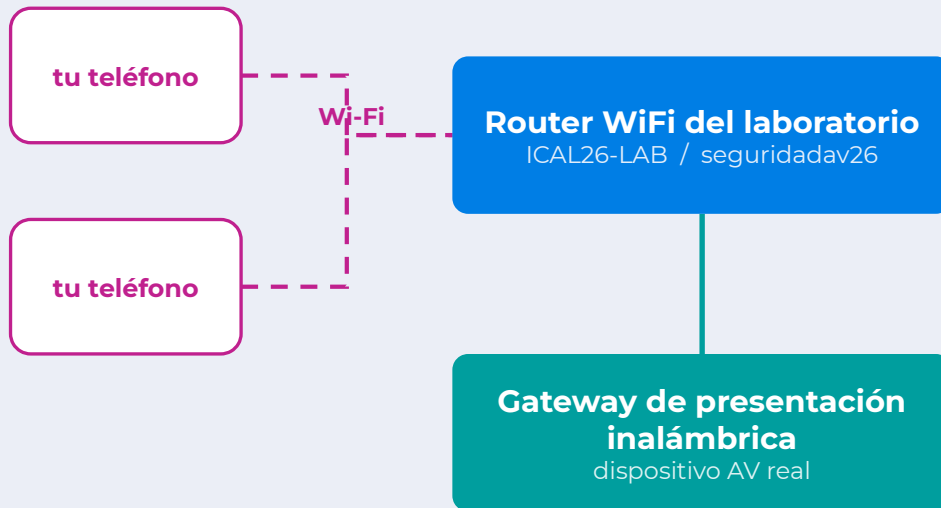
Impact

Resaltadas: Reconnaissance (nmap), Discovery (Wireshark), Credential Access y Lateral Movement. · Fuente: MITRE ATT&CK · IBM Think



Manos a la obra: conéctate al laboratorio

Red aislada - sin conexión con el WTC



Para participar

- 1 Conéctate a la red ICAL26-LAB (clave: seguridadav26).
- 2 Opcional, para ir más a fondo: instala un escáner de red. En el teléfono, Fing o Network Scanner; en laptop, nmap.
- 3 Escanea y mira lo que aparece. Seguimos la demo juntos.

Regla de oro

Escanea SOLO la red del laboratorio. Nunca la red del recinto (WTC): eso es intrusión.



Demo 1: reconocimiento con nmap



ATT&CK - Reconnaissance (TA0043)

Desde la red aislada, un escaneo revela cada host, sus puertos y sus servicios.

En segundos aparece el mapa completo: qué hay, qué versión corre, qué está expuesto.

El atacante no necesita entrar todavía. Solo mirar. Y ya sabe por dónde.

Si quieres, lo corres tú también desde tu teléfono, sobre la red del laboratorio.

```
nmap - red del laboratorio

$ nmap -sV 192.168.50.0/24

Starting Nmap 7.95 ( https://nmap.org )

Nmap scan report for router.lab (192.168.50.1)
Host is up (0.0021s latency).
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       dnsmasq 2.86
80/tcp    open  http         lighttpd 1.4.59

Nmap scan report for presentador.lab (192.168.50.23)
Host is up (0.0034s latency).
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          Dropbear sshd 2019.78
80/tcp    open  http         panel de administración (sin TLS)
443/tcp   open  ssl/http     certificado autofirmado
5353/udp   open  mdns         anuncia _airplay._tcp, _googlecast._tcp

Nmap done: 256 IP addresses (3 hosts up) scanned in 6.21 seconds
```

Ejemplo representativo: salida de nmap sobre la red del laboratorio



Demo 2: protocolos de casa (mDNS)



ATT&CK - Discovery (TA0007)

mDNS, AirPlay y compañía fueron diseñados para la red de tu casa: anuncian todo, sin autenticar.

Con Wireshark vemos a los equipos AV gritando su nombre, modelo y servicios a toda la red.

Es una de las razones principales por las que IT frena un proyecto AV.

Wireshark - wlan0 - filtro: mdns						
No.	Time	Source	Destination	Protocol	Length	Info
12	0.000000	192.168.50.23	224.0.0.251	MDNS	318	Standard query response 0x0000 PTR _airplay._tcp.local Presentador-SalaJuntas
13	0.000412	192.168.50.23	224.0.0.251	MDNS	292	Standard query response 0x0000 TXT model=presenter-gw fw=2.6.1 features=0x5A7FFFF7
14	0.003118	192.168.50.44	224.0.0.251	MDNS	101	Standard query 0x0000 PTR _googlecast._tcp.local "QM" question
15	0.003590	192.168.50.23	224.0.0.251	MDNS	264	Standard query response 0x0000 SRV Presentador-SalaJuntas._airplay._tcp.local port 7000
16	0.010204	192.168.50.1	224.0.0.251	MDNS	88	Standard query 0x0000 PTR _services._dns-sd._udp.local
17	0.011877	192.168.50.23	224.0.0.251	MDNS	240	Standard query response 0x0000 A Presentador-SalaJuntas.local 192.168.50.23

Ejemplo representativo: captura de Wireshark con tráfico mDNS del gateway de presentación



Fugas que, sumadas, dan contexto



Nada es grave por separado. Combinado, es el guion de un ataque dirigido.



Acceso inicial: la puerta ya estaba abierta

ATT&CK - Initial Access / Credential Access

Muchos equipos AV se instalan y se dejan con la credencial de fábrica.

admin/admin, o sin contraseña, en el panel web de control.

Desde ahí se lee la configuración, la agenda, los contactos y a veces se controla el equipo.

No seguro | http://192.168.50.23/login

Gateway de presentación - Panel de administración

Iniciar sesión

Usuario

admin

Contraseña

admin

[Entrar]

Acceso concedido. Sesión iniciada como admin.
Aviso: credenciales de fábrica sin cambiar.

Ejemplo representativo: panel de administración del equipo con credencial de fábrica



El objetivo no era apagar la pantalla. Era el correo de phishing que ahora es creíble.

Con nombres, cargos, salas y agenda reales, el atacante escribe un correo que el destinatario no duda en abrir. Eso es lo que está en juego.



Lo que dice AVIXA

AVIXA RP-C303.01

Prácticas recomendadas de seguridad en sistemas AV en red. Todo lo que sigue está ahí.

Identidad y acceso

Cambiar la contraseña de fábrica antes de instalar; 12 caracteres o más; roles de administrador y usuario.

§7.1

Parches y firmware

Proceso definido; probar la actualización antes de aplicarla y saber qué cambia.

§7.2

Cifrado

Si hay HTTPS, apagar HTTP. Sin TLS 1.1 ni SSLv3. Datos personales cifrados.

§7.3

Puertos y servicios

Documentar entrantes y salientes; apagar lo que no se usa, como Telnet o FTP.

§7.4, §7.7

VLAN propia para AV

Separada de la corporativa; hacia ella solo por router con ACL. 802.1X o MAB.

§7.5

Documentar y acordar

Inventario, topología con VLAN y ACL, roles. Responsabilidades por escrito con IT.

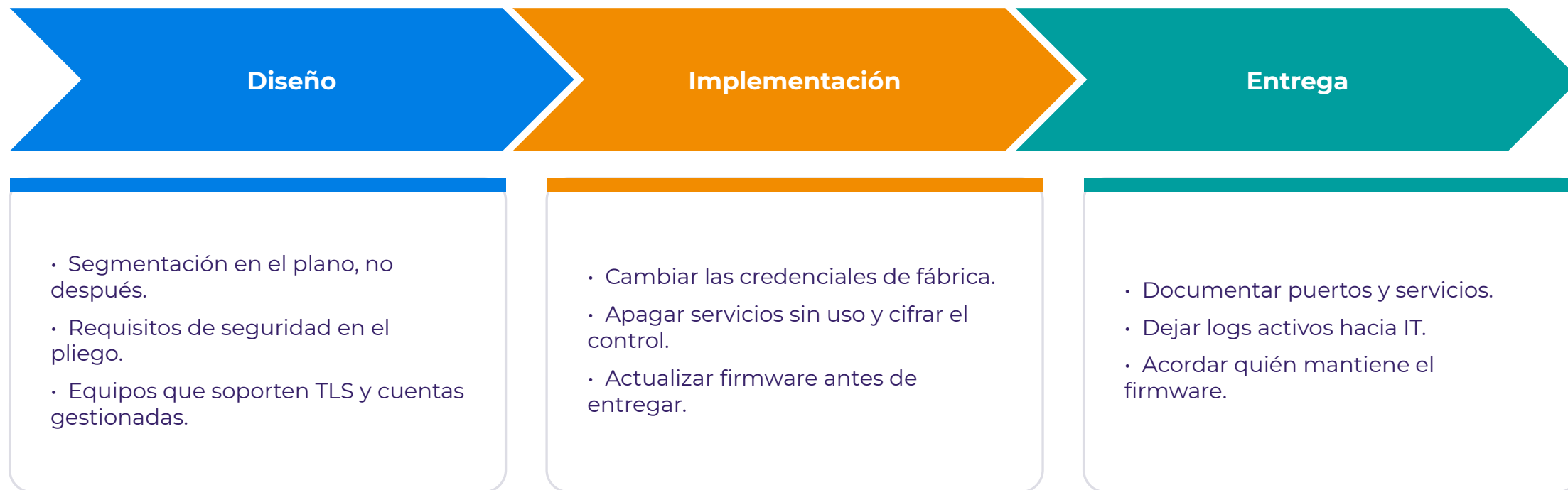
§9.1, §9.2

ANSI/AVIXA D402.02 añade el cuándo: se verifica en integración, post-integración y cierre.

Es el estándar del gremio. Pedirlo no es ser exigente: es cumplirlo.



Qué proponer: seguridad por fase del proyecto



La seguridad se diseña desde el día uno. No es un parche que se agrega al final.

ANSI/AVIXA D402.02 formaliza esta verificación por fase: pre-integración, integración, post-integración y cierre.



Segmentación: la propuesta que IT quiere escuchar

VLAN AV

dispositivos AV aislados

VLAN de control

plano de gestión separado

Firewall con reglas explícitas: solo lo necesario pasa • AVIXA RP-C303.01 \$7.5

De control a AV

gestión cifrada (SSH, HTTPS)

De corporativa a AV

solo lo acordado: calendario, directorio

De invitados a AV

bloqueado

Visibilidad: IT suele poner un sensor que escucha el tráfico de la VLAN AV sin tocar los equipos (en su jerga, un NIDS).

Red corporativa

datos de la empresa

Red de invitados

el visitante, nunca el AV

Todo lo demás, bloqueado. Es la propuesta que IT quiere escuchar.



Secure by default: checklist de hardening

Seguro por defecto, no por pedido

El equipo sale de tu mano ya endurecido. No esperas a que IT lo exija.

1

Credenciales

Cambiar las de fábrica y retirar las temporales de la instalación; cuentas administradas.

2

Superficie

Apagar servicios y protocolos sin uso: Telnet, mDNS, UPnP.

3

Firmware

Actualizar y acordar quién lo mantiene en el tiempo.

4

Cifrado

Control y gestión cifrados; nada de HTTP plano ni Telnet.

5

Visibilidad

Dejar logs activos y enviarlos a donde IT los vea.

Cinco cosas antes de entregar. Si el cliente no las pide, las haces igual.

Alineado con la línea base de seguridad de AVIXA RP-C303.01, §7.



Las preguntas que IT te va a hacer (y cómo responder)

¿Qué puertos abre este equipo?

Lista documentada de puertos y servicios.

¿En qué red va a estar?

En la VLAN AV, segmentada, con reglas explícitas.

¿Cómo se gestionan las credenciales?

Cuentas administradas; nada de fábrica.

¿Cómo actualizamos y monitoreamos?

Plan de firmware y logs hacia su sistema de monitoreo (en su jerga, SIEM).

Tener esto listo convierte la revisión de IT en un trámite, no en un freno.

Es la documentación que pide AVIXA RP-C303.01 §9.2: puertos y servicios, topología con VLAN y ACL, roles y permisos.



Cuando el cliente no tiene políticas formales

Muchos clientes no tienen un área de seguridad madura. Ahí el integrador marca la diferencia.

Lleva tú el mínimo

Segmentación, credenciales,
cifrado y logs.
Como estándar, no como extra.

Documéntalo

Hazlo parte de la entrega.
Protege al cliente y te protege a ti.

Conviértelo en diferencial

No es un costo: es tu ventaja
comercial.
Es lo que te distingue frente a otro
integrador.

Eres el integrador que entrega seguro por defecto.



Para llevar: marcos y herramientas

Estándares AVIXA

AVIXA RP-C303.01

Prácticas recomendadas de seguridad en sistemas AV en red. La línea base de este taller.
avixa.org/standards

ANSI/AVIXA D402.02

Verificación de desempeño de sistemas AV, por fases del proyecto.
avixa.org/standards

Marcos

NIST CSF 2.0

Marco de gestión de riesgo que usa IT.
nist.gov/cyberframework

MITRE ATT&CK

Catálogo de tácticas y técnicas reales.
attack.mitre.org

Cyber Kill Chain

Las fases de un ataque (Lockheed Martin).
lockheedmartin.com/.../cyber-kill-chain

CIS Controls v8.1

18 controles priorizados para implementar.
cisecurity.org/controls

Herramientas y lecturas

Nmap

Escaneo de red y de servicios.
nmap.org

Wireshark

Análisis de tráfico (mDNS y más).
wireshark.org

MITRE ATT&CK explicado

Qué es una táctica y una técnica (con video).
ibm.com/think/mitre-attack

En el kit descargable:

Checklist de hardening, guía del laboratorio y guion de preguntas de IT.



Llévate el kit

1

Checklist de hardening

Para auditar tus proyectos antes de que IT los revise.

2

Guía para montar tu laboratorio

Red aislada y USB de arranque para practicar en casa.

3

Guion de preguntas de IT

Con las respuestas que te dejan pasar la revisión.



Escanea para descargar el kit

Juan Pineda · Pyxis

✉ juan.pineda@pyxis.tech



[linkedin.com/in/jdpinedac](https://www.linkedin.com/in/jdpinedac)

Eduardo Travi · AVI SPL

✉ Eduardo.Travi@avispl.com



[linkedin.com/in/eduardotravi](https://www.linkedin.com/in/eduardotravi)



De la teoría a la práctica: la prueba de concepto con SIP.

Eduardo Travi, de AVI SPL, continúa con la prueba de concepto sobre telefonía SIP.

Headline Partner: **AVI**  **SPL**

Patrocinador Gold:  **audio-technica**

infocomm
AMÉRICA LATINA